PRACTICAL 2: OWASP Top 10 Vulnerability Scanning using Burp Suite

Objective:

Identify OWASP Top 10 vulnerabilities in a given web application.

Tool Required:

- Burp Suite (Community Edition)

Expected Outcome:

Comprehensive vulnerability report with identified flaws.

Theory:

OWASP (Open Web Application Security Project) publishes a list of the top 10 most critical web application security risks. Scanning for these vulnerabilities ensures the web application is secure against the most common and impactful threats. The Top 10 includes risks like Injection, Broken Authentication, Cross-Site Scripting (XSS), Insecure Deserialization, and more.

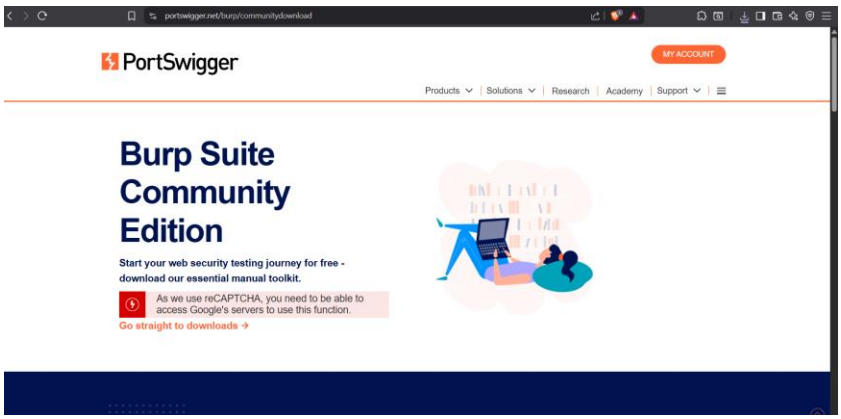
To perform vulnerability scanning, we use tools that simulate attacks and monitor how the application responds. In this practical, we will use Burp Suite to manually identify and analyze vulnerabilities in a web application.

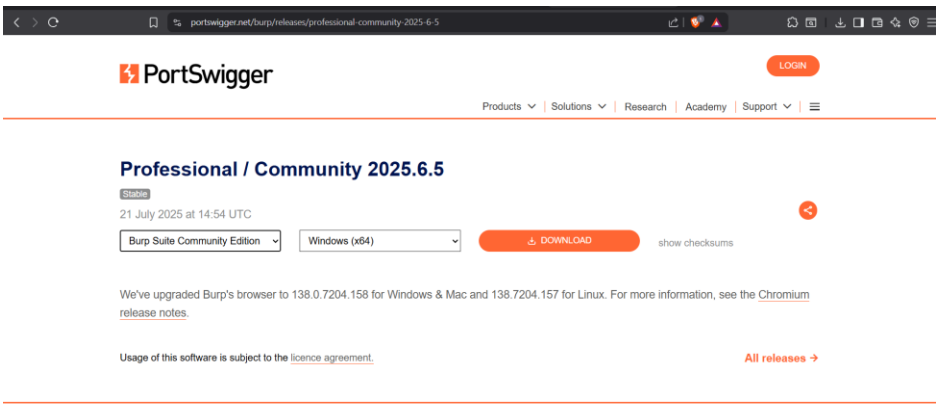
Steps for Performing OWASP Top 10 Vulnerability Scanning Using Burp Suite:

Setup & Scan Using Burp Suite (Community Edition)

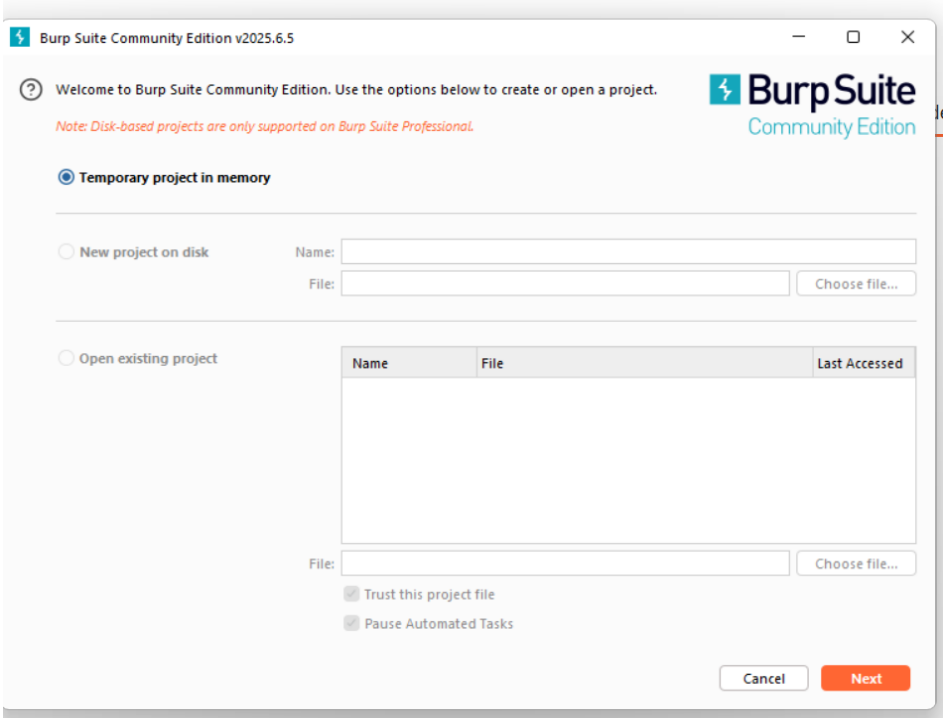
1. Install BURP SUITE (Community Edition)

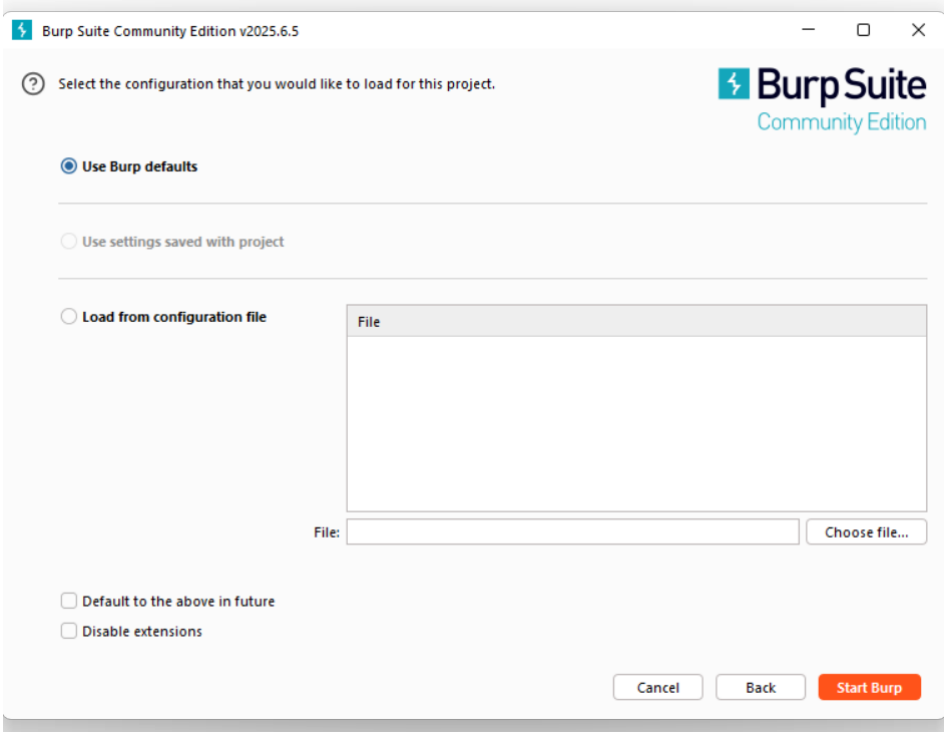
Download & Install burp suite form https://portswigger.net/burp/communitydownload



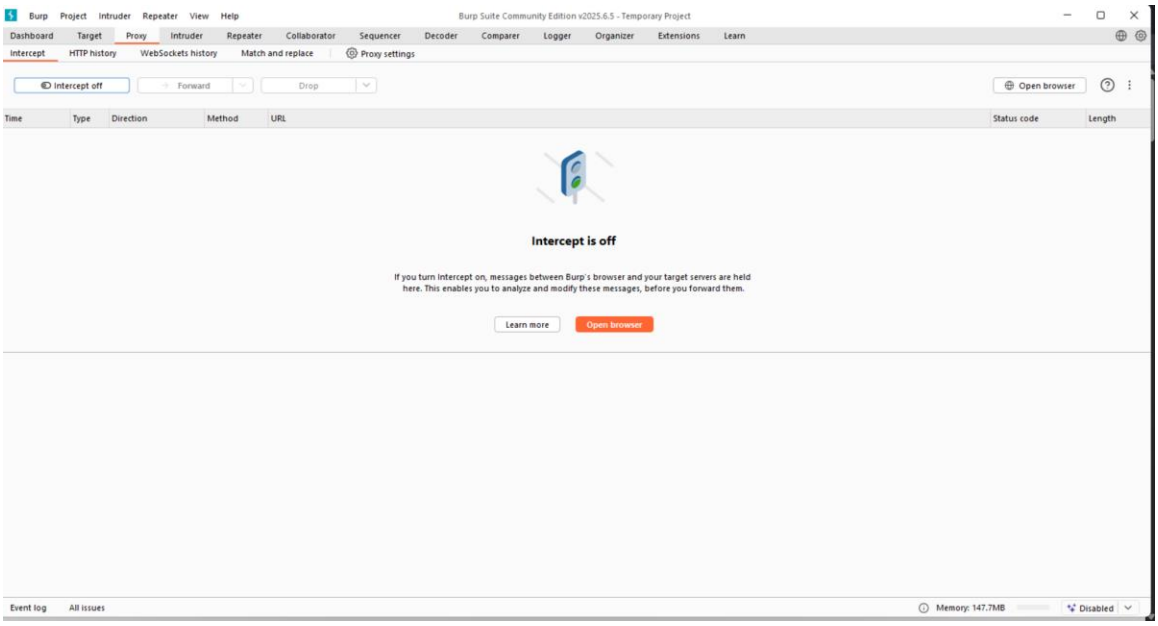


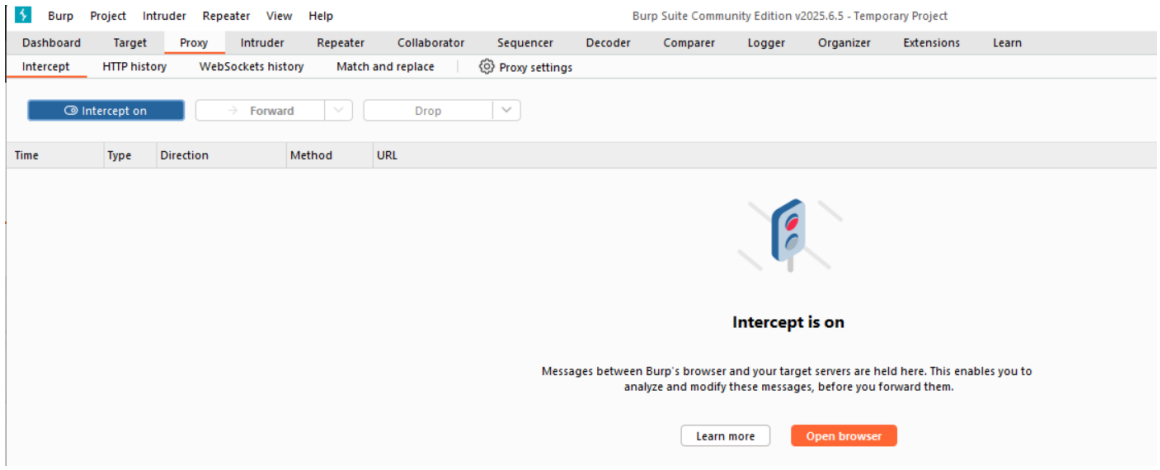
2. Open Burp Suite:
   - Launch the Burp Suite Community Edition.



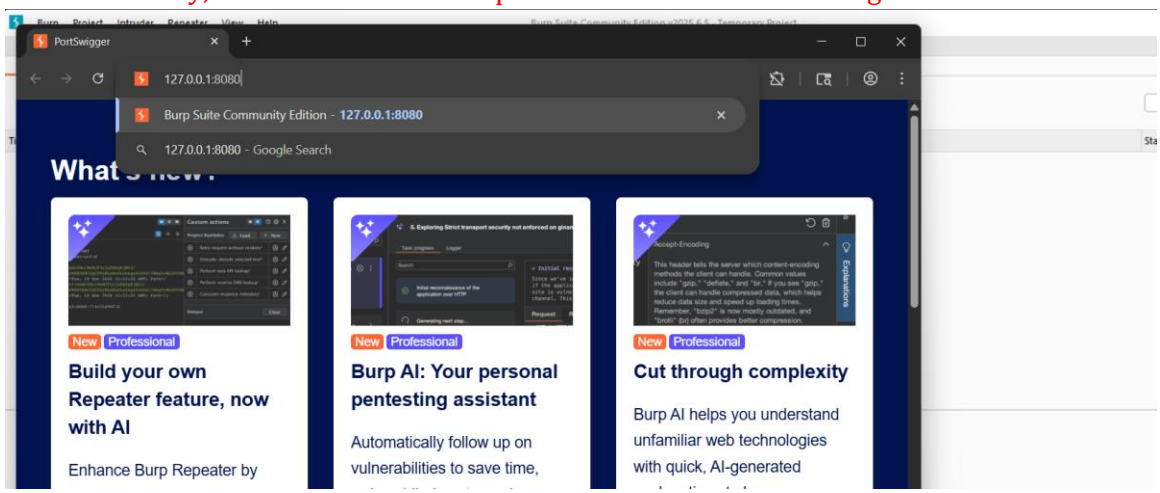


3. Set Up Burp Proxy Listener:
   - Go to the "Proxy" tab.
   - Click on the "Options" sub-tab.
   - Ensure the proxy listener is running on interface 127.0.0.1 and port 8080.

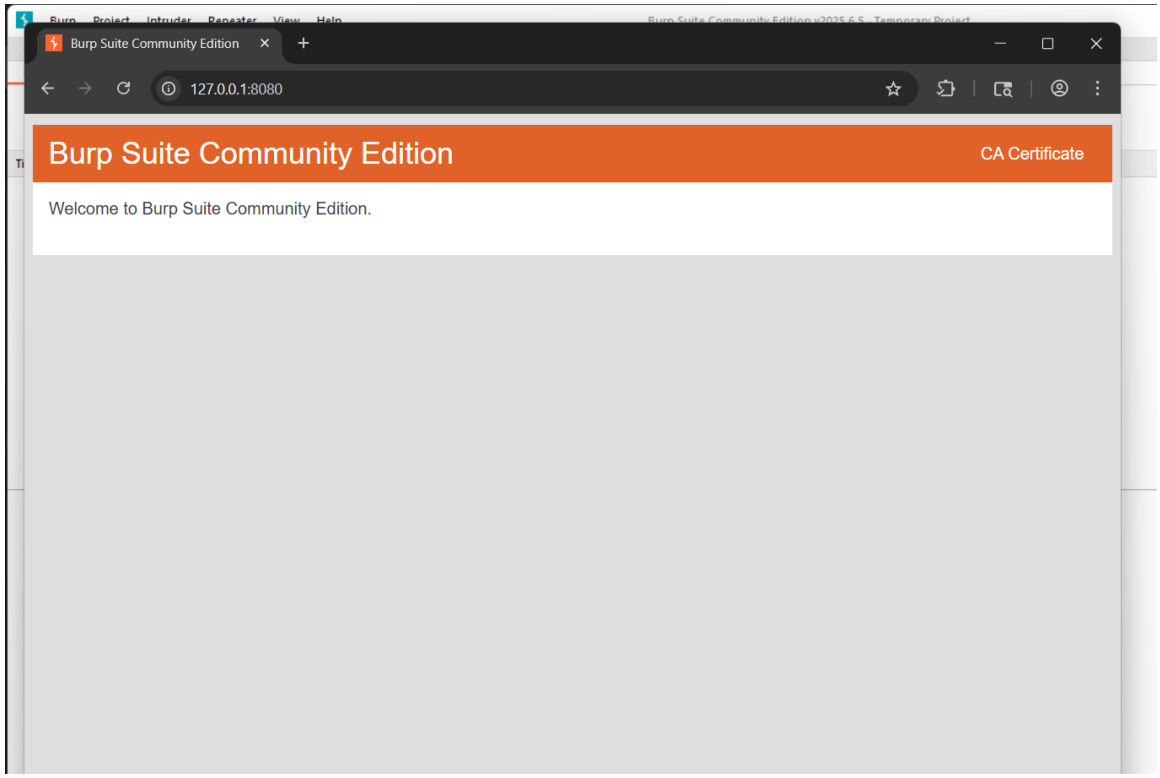




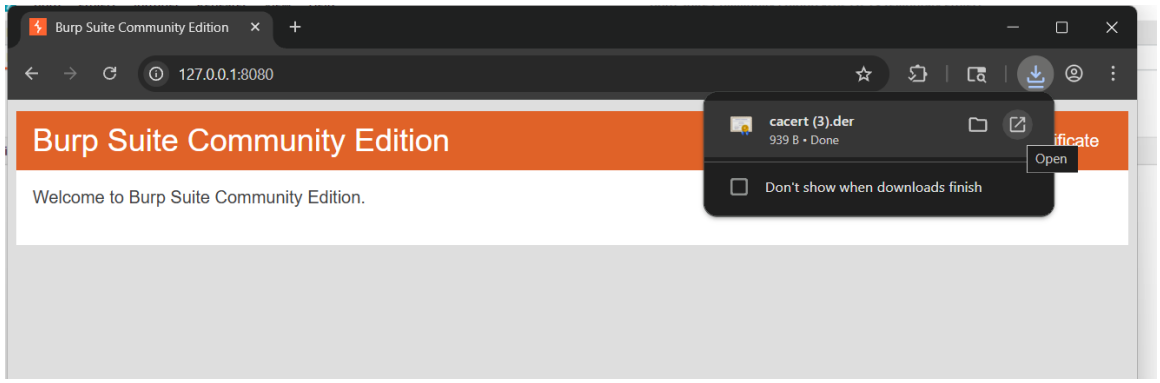
4. Configure Browser Proxy Settings:
   - Set your browser proxy settings to use 127.0.0.1 as the HTTP proxy and 8080 as the port.
   - Alternatively, install and use the Burp browser for automatic configuration.



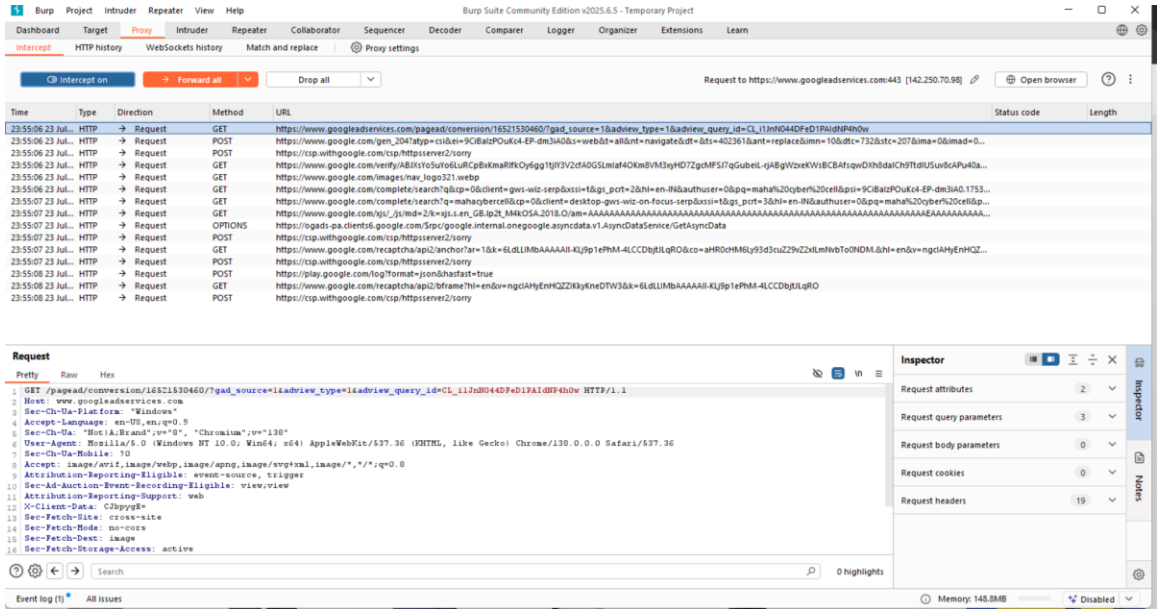
5. Intercept Traffic:
   - Enable "Intercept is on" in the "Proxy" tab.
   - Open the DVWA web application in your browser.
   - Burp will capture the requests.

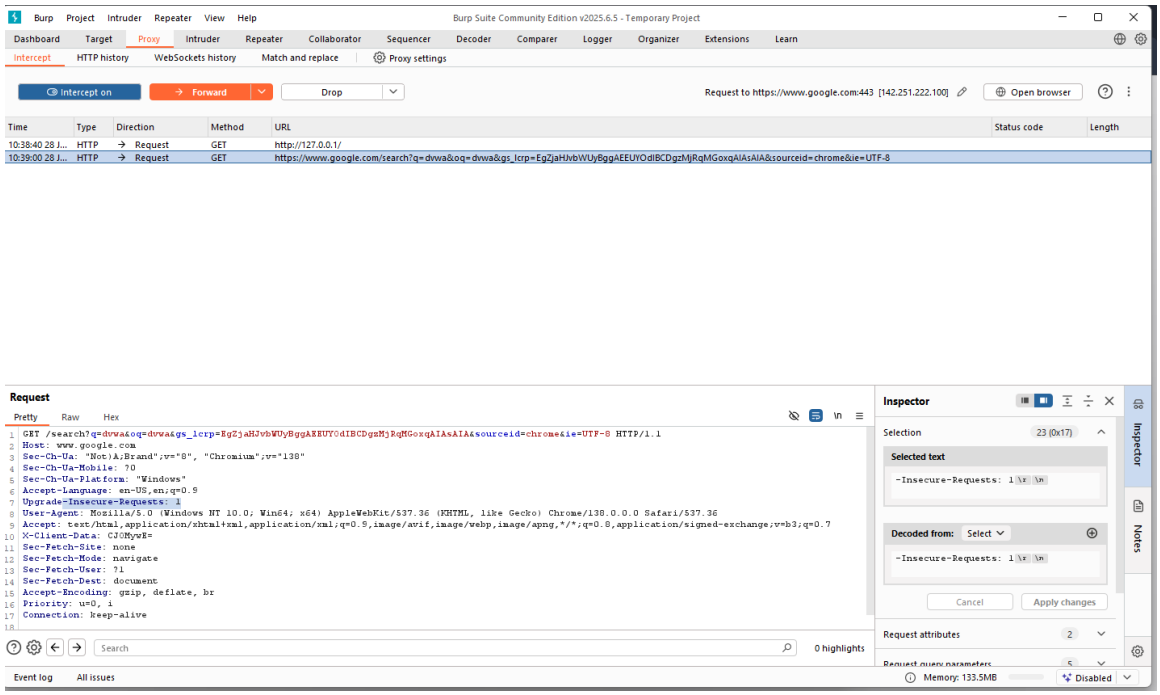


6. Send Requests to Target Tab:
   - Right-click on captured requests and select "Send to Target".
   - Burp will begin building the site map.



7. Manual Vulnerability Testing:
   - Use the "Proxy", "Repeater", and "Intruder" tabs for manual testing of inputs.
   - Try injecting SQL, XSS, or other payloads into the parameters.





8. Analyzing Responses:
   - Observe responses to detect anomalies or signs of vulnerability (e.g., error messages, JavaScript execution).

Conclusion:

By scanning the DVWA application using Burp Suite, we were able to identify and understand various OWASP Top 10 vulnerabilities. This practical helps in learning real-world web application security testing techniques and prepares us to secure applications in live environments.